

Fundamentals of Information Systems Security

Case Study: The WannaCry Ransomware Attack (2017)

How an NSA Exploit, a Leaked Vulnerability, and Unpatched Systems
Paralyzed the World

Executive Summary

On May 12, 2017, the world witnessed one of the most devastating cyberattacks in history. WannaCry, a ransomware worm, infected over 200,000 computers across 150 countries within hours[reference:43][reference:44]. The attack exploited a vulnerability in Microsoft's Server Message Block (SMB) protocol that had been discovered by the National Security Agency (NSA) and later leaked by a hacking group called The Shadow Brokers[reference:45][reference:46]. Despite a patch being available for two months prior to the attack, countless organizations—including the UK's National Health Service (NHS)—remained vulnerable[reference:47]. This case study examines the technical mechanisms, global impact, and critical lessons from the WannaCry outbreak.

What Is WannaCry?

WannaCry (also known as WannaCrypt, Wana Decrypt0r, or WCry) is a ransomware worm that combines two distinct types of malicious software[reference:48]:

- **Ransomware:** Encrypts files and demands payment (in Bitcoin) for decryption
- **Worm:** Self-propagates across networks without user interaction

Unlike traditional ransomware that relies on phishing emails to spread, WannaCry could autonomously replicate itself across networks[reference:49]. This combination made it particularly devastating and difficult to contain.

Technical Background: The EternalBlue Exploit

The NSA's Role

EternalBlue was a cyberweapon developed by the United States National Security Agency (NSA)[reference:50][reference:51]. The exploit targeted a critical vulnerability in Microsoft's implementation of the Server Message Block (SMB) protocol, specifically SMB version 1 (SMBv1)[reference:52].

The Leak

In April 2017, a hacking group called The Shadow Brokers leaked EternalBlue and other NSA exploits to the public[reference:53][reference:54]. The group claimed to have stolen these cyberweapons from the NSA-linked Equation Group[reference:55].

The Vulnerability (CVE-2017-0144)

EternalBlue exploited CVE-2017-0144, a critical vulnerability in Microsoft's SMBv1 protocol that allowed remote code execution without authentication[reference:56][reference:57]. Any Windows system that accepted SMBv1 requests was at risk[reference:58].

Key Technical Details

- **Vulnerability:** CVE-2017-0144 (EternalBlue)
- **Protocol:** Microsoft SMBv1
- **Impact:** Remote code execution without authentication
- **Patch:** MS17-010 (released March 2017)
- **Attack Date:** May 12, 2017
- **Systems Affected:** 200,000+ in 150+ countries

How WannaCry Spread

WannaCry's propagation mechanism was its most innovative and dangerous feature[reference:59]:

1. **Initial Infection:** A system was infected through traditional means (e.g., a malicious email attachment or direct network exploitation)
2. **Internal Scanning:** Once inside, WannaCry scanned the local network for other vulnerable systems using EternalBlue[reference:60]
3. **Self-Replication:** When a vulnerable system was found, WannaCry replicated itself automatically, without any user interaction[reference:61]
4. **Encryption:** On each infected system, WannaCry encrypted files using strong cryptographic algorithms and displayed a ransom note[reference:62]
5. **Ransom Demand:** Victims were asked to pay approximately \$300 in Bitcoin, with the amount increasing over time[reference:63]

Timeline of Events

March 14, 2017: Patch Released

Microsoft released security bulletin MS17-010, which patched the SMBv1 vulnerability[reference:64][reference:65]. The patch covered all supported Windows operating systems (Windows Vista and later)[reference:66].

April 2017: Exploit Leaked

The Shadow Brokers leaked EternalBlue to the public[reference:67].

May 12, 2017: Attack Begins

WannaCry began spreading globally, infecting over 200,000 systems in more than 150 countries within hours[reference:68].

May 12, 2017: Kill Switch Discovered

Security researcher Marcus Hutchins (aka MalwareTech) discovered a kill switch in the WannaCry code[reference:69]. The malware attempted to connect to an unregistered domain (www.iuqerfsodp9ifjapo). By registering this domain, Hutchins effectively slowed and partially stopped the worm's global spread[reference:70].

May 13-15, 2017: Global Response

Organizations worldwide scrambled to apply the MS17-010 patch, disable SMBv1, and contain the spread.

Impact on the UK's National Health Service (NHS)

The WannaCry attack had a particularly devastating impact on the NHS[reference:71][reference:72]. Approximately 48 NHS organizations were affected[reference:73].

Specific Impacts

- **Ambulance Services:** Handover process screens were disabled; pre-alerts had to be communicated by landline[reference:74][reference:75]
- **Patient Transport:** Booking portals were unavailable, reverting to telephone bookings[reference:76][reference:77]
- **Tertiary Care:** CT and MRI scans could not be transferred electronically, requiring DVD transport by taxi[reference:78][reference:79]
- **Chemotherapy:** Chemo Care orders could not be transferred, reverting to paper and fax[reference:80][reference:81]
- **Primary Care:** Automated transfer of blood results failed; GPs had limited access to caseloads[reference:82][reference:83]

Why Was the NHS So Vulnerable?

1. **Outdated Systems:** Many NHS computers were still running Windows XP, which Microsoft no longer supported[reference:84]
2. **Delayed Patching:** Despite warnings, many NHS organizations had not applied the MS17-010 patch[reference:85]
3. **Legacy Medical Devices:** Critical medical devices (e.g., MRI machines, infusion pumps) ran on older systems that could not be easily patched[reference:86]
4. **Budget Constraints:** The NHS faced significant funding challenges that limited IT modernization

Who Was Behind WannaCry?

Security researchers tentatively linked the WannaCry ransomware worm to the Lazarus Group, a nation-state advanced persistent threat (APT) group with ties to the North Korean government[reference:87]. The attribution was based on:

- Code similarities with previous Lazarus Group malware

- Infrastructure overlaps
- Operational patterns consistent with North Korean cyber operations

Why Did So Many Organizations Remain Vulnerable?

Despite a patch being available for two months, the attack was still devastating[reference:88][reference:89]:

1. **Patch Management Failures:** Many organizations lacked effective patch management processes
2. **Outdated Operating Systems:** Windows XP and other unsupported systems were still in widespread use[reference:90]
3. **Legacy System Constraints:** Many organizations could not patch critical systems due to compatibility concerns[reference:91]
4. **Lack of Visibility:** Organizations did not know which systems were vulnerable
5. **Complacency:** The severity of the vulnerability was underestimated

Lessons Learned

Lesson 1: Patch Management Is Critical

A patch was available for two months before the attack[reference:92]. Organizations must have robust processes to identify and apply patches quickly[reference:93].

Lesson 2: Retire Legacy Systems

Outdated operating systems create significant security risks. Organizations should have a documented plan to upgrade or replace unsupported systems[reference:94].

Lesson 3: Implement Defense in Depth

Network segmentation, firewalls, and intrusion detection systems can limit the spread of worms[reference:95]. Blocking SMBv1 packets from public networks prevented infection[reference:96].

Lesson 4: Incident Response Planning Is Essential

The NHS response demonstrated the importance of business continuity plans[reference:97]. Organizations must have procedures for:

- Manual workarounds
- Communication during incidents
- Data backup and recovery

Lesson 5: Basic Cyber Hygiene Prevents Major Incidents

As one expert noted, "Basic IT security could have prevented the NHS from being such a significant victim of May's WannaCry ransomware outbreak"[reference:98].

Lesson 6: Collaboration Matters

The discovery of the kill switch by Marcus Hutchins demonstrates the value of the security research community in mitigating attacks[reference:99].

Discussion Questions

1. Should the NSA have disclosed the SMB vulnerability when it was discovered rather than stockpiling it as a cyberweapon?
2. How could the NHS have better protected itself against WannaCry?
3. What is the responsibility of software vendors (like Microsoft) in supporting legacy systems?
4. How should organizations balance the need for rapid patching against the risk of system instability?
5. What role should governments play in preventing and responding to ransomware attacks?

References

- TechTarget. (2025). What is the WannaCry Ransomware Attack?
- Security Affairs. (2026). WannaCry, the ransomware attack that changed the history of cybersecurity.
- NHS England. (2017). WannaCry Attack Case Study.
- ZDNet. (2017). WannaCry ransomware: Hospitals were warned to patch system to protect against cyber-attack - but didn't.